

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Bermuda - Bermuda Monetary Authority (BMA) Insurance Sector Operational Cyber Risk Management Code of Conduct (2020)**

Focal Document URL: <https://www.bma.bm/viewPDF/documents/2020-10-06-09-27-29-Insurance-Sector-Cyber-Risk-Management-Code-of-Conduct.pdf>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-americas-bmu-mba-coc-2020.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
1	Legislative Basis and Scope of Code	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
2	Introduction	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
3	Interpretation	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
4	Proportionality Principle	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
5	SECTION I - IDENTIFICATION OF ASSETS AND RISKS	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
5.1	Board Level Governance of Cyber Risk	The board of directors and senior management team must have oversight of cyber risks. The board of directors must approve a cyber risk policy document at least on an annual basis. The cyber risk may be covered in a standalone cyber risk policy document or expressly set forth as a section in a broader risk policy document, e.g., the operational risk policy. Regular updates detailing the overall cyber risk status must be made available to the board and senior management team.	Functional	Intersects With	Steering Committee & Program Oversight	GOV-01.1	Mechanisms exist to align security, compliance and resilience capabilities with business requirements through a steering committee or advisory board, comprised of key cybersecurity, data protection and business executives, which meets formally and on a regular basis.	8	
5.2	The Role of the Chief Information Security Officer (CISO)	The role of CISO must be allocated to the appropriately qualified member of staff or the outsourced resource. It should be noted, however, that if the role is outsourced, oversight responsibility remains with the Board. The role of the CISO is to deliver the operational cyber risk management programme. The CISO role is expected to be of sufficient seniority to facilitate the delivery of the operational cyber risk management programme.	Functional	Intersects With	Assigned Security, Compliance & Resilience Responsibilities	GOV-04	Mechanisms exist to assign one or more qualified individuals with the mission and resources to centrally-manage, coordinate, develop, implement and maintain an enterprise-wide Security, Compliance & Resilience Program (SCRPP).	8	
5.3	The Operational Cyber Risk Management Programme	The objectives of the cyber risk policy must be delivered by an operational cyber risk management programme. This must include: The programme defines, documents and communicates policies, processes and procedures that direct the management of cyber risk.	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	
5.3	The Operational Cyber Risk Management Programme	The objectives of the cyber risk policy must be delivered by an operational cyber risk management programme. This must include: The programme defines, documents and communicates policies, processes and procedures that direct the management of cyber risk.	Functional	Intersects With	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with:	5	
5.3-BP1	The Operational Cyber Risk Management Programme	A risk assessment process to identify, evaluate, and manage cyber risks	Functional	Intersects With	Risk Identification	RSK-03	(1) The organization's Enterprise Risk Management (ERM); and	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.3-BP1	The Operational Cyber Risk Management Programme	A risk assessment process to identify, evaluate, and manage cyber risks	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.3-BP1	The Operational Cyber Risk Management Programme	A risk assessment process to identify, evaluate, and manage cyber risks	Functional	Intersects With	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.3-BP2	The Operational Cyber Risk Management Programme	Data governance, classification controls and information security controls	Functional	Intersects With	Data Governance	GOV-10	Mechanisms exist to facilitate data governance to oversee the organization's policies, standards and procedures so that sensitive and/or regulated data is effectively managed and maintained in accordance with applicable statutory, regulatory and contractual obligations.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.3-BP2	The Operational Cyber Risk Management Programme	Data governance, classification controls and information security controls	Functional	Intersects With	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.3-BP2	The Operational Cyber Risk Management Programme	Data governance, classification controls and information security controls	Functional	Intersects With	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.3-BP3	The Operational Cyber Risk Management Programme	Detection, protection, response and recovery controls	Functional	Intersects With	Data Protection	DCH-01	Mechanisms exist to facilitate the implementation of data protection controls.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.3-BP3	The Operational Cyber Risk Management Programme	Detection, protection, response and recovery controls	Functional	Intersects With	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.3-BP3	The Operational Cyber Risk Management Programme	Detection, protection, response and recovery controls	Functional	Intersects With	Secure Engineering Principles	SEA-01	Mechanisms exist to facilitate the implementation of industry-recognized security, compliance and resilience practices in the specification, design, development, implementation and modification of Technology Assets, Applications and/or Services (TAAS).	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.4	The Three Lines of Defense (3LOD)	The Authority requires that cyber risk governance should follow a 3LOD model, namely: operational management, risk management and audit.	Functional	Subset Of	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	10	
5.5	Risk Assessment Process	The operational cyber risk management programme must include a risk assessment process which comprises of: The registrant's risk assessments must be documented and retained for at least five years in a manner that allows the reports to be provided to the Authority upon request.	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
5.5	Risk Assessment Process	The operational cyber risk management programme must include a risk assessment process which comprises of: The registrant's risk assessments must be documented and retained for at least five years in a manner that allows the reports to be provided to the Authority upon request.	Functional	Intersects With	Media & Data Retention	DCH-18	Mechanisms exist to retain media and data in accordance with applicable statutory, regulatory and contractual obligations.	5	
5.5-BP1	Risk Assessment Process	Identification: the organisation understands the cyber risk to operations, assets and individuals	Functional	Equal	Risk Identification	RSK-03	Mechanisms exist to identify and document risks, both internal and external.	10	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.5-BP2	Risk Assessment Process	Measurement: the organisation understands the potential impact and consequences of these risks	Functional	Equal	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	10	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.5-BP3	Risk Assessment Process	Response: for each type of risk identified, a risk response must be decided; the risk response should be consistent with the criticality of the asset; and the level of risk tolerance	Functional	Equal	Risk Remediation	RSK-06	Mechanisms exist to remediate risks to an acceptable level.	10	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.5-BP4	Risk Assessment Process	Monitoring and reporting: a risk register should be maintained to monitor risks	Functional	Equal	Risk Register	RSK-04.1	Mechanisms exist to maintain a risk register that facilitates monitoring and reporting of risks.	10	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.6	IT Audit Plan	The third line of defence, IT audit, should provide the audit committee of the Board (or equivalent) an independent and objective assessment of the effectiveness of controls. An IT audit plan should be developed and approved by the audit committee of the board or its equivalent. Audits may be carried out by a qualified internal audit resource or by a qualified third-party company.	Functional	Subset Of	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	10	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>

Focal Document: **Bermuda - Bermuda Monetary Authority (BMA) Insurance Sector Operational Cyber Risk Management Code of Conduct (2020)**

Focal Document URL: <https://www.bma.bm/viewPDF/documents/2020-10-06-09-27-29-Insurance-Sector-Cyber-Risk-Management-Code-of-Conduct.pdf>

Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-americas-bmu-mba-coc-2020.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
5.7	The Re-evaluation of Controls	The control environment should be continuously monitored and evaluated in order to:	Functional	Subset Of	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	10	
5.7-BP1	The Re-evaluation of Controls	Identify control deficiencies and to initiate improvement actions	Functional	Intersects With	Functional Review Of Security, Compliance & Resilience Controls	CPL-03.2	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for adherence to the organization's security, compliance and/or resilience policies and standards.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.7-BP2	The Re-evaluation of Controls	Plan, organise and maintain standards for internal control assessment and assurance activities	Functional	Subset Of	Security, Compliance & Resilience Controls Oversight	CPL-02	Mechanisms exist to provide a security, compliance and resilience controls oversight function that reports to the organization's executive leadership.	10	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.7-BP3	The Re-evaluation of Controls	Evaluate whether the control environment is compliant with laws, regulations and contractual requirements	Functional	Intersects With	Conformity Assessment	CPL-01.4	Mechanisms exist to conduct assessments to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	8	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.8	Cyber Insurance	One of the risk responses available is to transfer the risk to a third party. Registrants should consider the benefits of purchasing a cyber insurance policy which may be used to mitigate financial loss from a cyber incident. Registrants should review the adequacy of its cyber insurance coverage at least on an annual basis.	Functional	Subset Of	Risk Treatment Options	RSK-06.3	Mechanisms exist to select appropriate risk treatment options, based on applicable risk assessment findings, including: (1) Mitigating the risk to an acceptable level; (2) Avoiding the risk (e.g., terminating the project); (3) Transferring the risk to a third party (e.g., insurance, service	10	
5.9	Identify Assets	An asset inventory should be put in place, detailing all information assets. The information must be classified in terms of its value, legal requirements, sensitivity and criticality to the organisation.	Functional	Subset Of	Asset Inventories	AST-02	Mechanisms exist to perform inventories of Technology Assets, Applications, Services and/or Data (TAASD) that: (1) Accurately reflects the current TAASD in use; (2) Identifies authorized software products, including business justification details; (3) Is at the level of granularity deemed necessary for tracking and reporting; (4) Includes organization-defined information deemed necessary to achieve effective property accountability; and (5) Is available for review and audit by designated organizational personnel.	10	
5.9-BP1	Identify Assets	All information assets should be owned by a designated part of the business	Functional	Intersects With	Asset Ownership Assignment	AST-03	Mechanisms exist to ensure asset ownership responsibilities are assigned, tracked and managed at a team, individual, or responsible organization level to establish a common understanding of requirements for asset protection.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.9-BP2	Identify Assets	Information owners are responsible for classifying information and information assets	Functional	Intersects With	Asset Ownership Assignment	AST-03	Mechanisms exist to ensure asset ownership responsibilities are assigned, tracked and managed at a team, individual, or responsible organization level to establish a common understanding of requirements for asset protection.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.9-BP2	Identify Assets	Information owners are responsible for classifying information and information assets	Functional	Intersects With	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.9-BP3	Identify Assets	Classifications and associated protective controls for information should take account of business needs for sharing or restricting information and the business impacts associated with such needs	Functional	Intersects With	Disclosure of Information	DCH-03.1	Mechanisms exist to restrict the disclosure of sensitive and/or regulated data to authorized parties with a need to know.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.9-BP4	Identify Assets	An appropriate set of procedures for information labelling and handling should be developed and implemented	Functional	Intersects With	Standardized Operating Procedures (SOP)	OPS-01.1	Mechanisms exist to identify and document Standardized Operating Procedures (SOP), or similar documentation, to enable the proper execution of day-to-day / assigned tasks.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.10	Managing Outsourcing and Third-Party Service Provider Cyber Risk	Where the registrant outsources functions either externally to third parties or internally to other affiliated entities, the registrant must ensure there is the oversight and clear accountability for all outsourced functions as if these functions were performed internally, and subject to the registrant's own standards of governance and internal controls. The registrant must also ensure the service agreement includes terms on compliance with jurisdictional laws and regulations, cooperation with the Authority, and access to data and records in a timely manner. The senior management team must understand the risks associated with IT outsourcing. It is important to note an organisation can never outsource responsibility for governance and risk. Contractual terms and conditions must be defined, governing the roles, relationships, obligations and responsibilities of all contracting parties.	Functional	Subset Of	Third-Party Management	TPM-01	Mechanisms exist to facilitate the implementation of third-party management controls.	10	
5.10	Managing Outsourcing and Third-Party Service Provider Cyber Risk	Where the registrant outsources functions either externally to third parties or internally to other affiliated entities, the registrant must ensure there is the oversight and clear accountability for all outsourced functions as if these functions were performed internally, and subject to the registrant's own standards of governance and internal controls. The registrant must also ensure the service agreement includes terms on compliance with jurisdictional laws and regulations, cooperation with the Authority, and access to data and records in a timely manner. The senior management team must understand the risks associated with IT outsourcing. It is important to note an organisation can never outsource responsibility for governance and risk. Contractual terms and conditions must be defined, governing the roles, relationships, obligations and responsibilities of all contracting parties.	Functional	Intersects With	Third-Party Risk Assessments & Approvals	TPM-04.1	Mechanisms exist to conduct a risk assessment prior to the acquisition or outsourcing of technology-related Technology Assets, Applications and/or Services (TAAS).	5	
5.10	Managing Outsourcing and Third-Party Service Provider Cyber Risk	Where the registrant outsources functions either externally to third parties or internally to other affiliated entities, the registrant must ensure there is the oversight and clear accountability for all outsourced functions as if these functions were performed internally, and subject to the registrant's own standards of governance and internal controls. The registrant must also ensure the service agreement includes terms on compliance with jurisdictional laws and regulations, cooperation with the Authority, and access to data and records in a timely manner. The senior management team must understand the risks associated with IT outsourcing. It is important to note an organisation can never outsource responsibility for governance and risk. Contractual terms and conditions must be defined, governing the roles, relationships, obligations and responsibilities of all contracting parties.	Functional	Intersects With	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	5	
5.10	Managing Outsourcing and Third-Party Service Provider Cyber Risk	Where the registrant outsources functions either externally to third parties or internally to other affiliated entities, the registrant must ensure there is the oversight and clear accountability for all outsourced functions as if these functions were performed internally, and subject to the registrant's own standards of governance and internal controls. The registrant must also ensure the service agreement includes terms on compliance with jurisdictional laws and regulations, cooperation with the Authority, and access to data and records in a timely manner. The senior management team must understand the risks associated with IT outsourcing. It is important to note an organisation can never outsource responsibility for governance and risk. Contractual terms and conditions must be defined, governing the roles, relationships, obligations and responsibilities of all contracting parties.	Functional	Intersects With	Responsible, Accountable, Supportive, Consulted & Informed (RASCI) Matrix	TPM-05.4	Mechanisms exist to document and maintain a Responsible, Accountable, Supportive, Consulted & Informed (RASCI) matrix, or similar documentation, to delineate assignment for security, compliance and resilience controls between internal stakeholders and External Service Providers (ESPs).	5	
5.11	Cloud Computing	The use of cloud computing services must be risk-assessed. The risk profile of cloud computing must be assessed according to the type of cloud architecture, i.e. public cloud, private cloud, community cloud and hybrid cloud. A cloud risk assessment must include an analysis of security architecture and operations, as well as the following topics: As part of the cloud risk assessment, a review of roles and responsibilities must be completed to define which party is responsible for operating and monitoring each cyber risk control.	Functional	Intersects With	Cloud Services	CLD-01	Mechanisms exist to facilitate the implementation of cloud management controls to ensure cloud instances are secure and in-line with industry practices.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
5.11	Cloud Computing	The use of cloud computing services must be risk-assessed. The risk profile of cloud computing must be assessed according to the type of cloud architecture, i.e. public cloud, private cloud, community cloud and hybrid cloud. A cloud risk assessment must include an analysis of security architecture and operations, as well as the following topics: As part of the cloud risk assessment, a review of roles and responsibilities must be completed to define which party is responsible for operating and monitoring each cyber risk control.	Functional	Intersects With	Customer Responsibility Matrix (CRM)	CLD-06.1	Mechanisms exist to formally document a Customer Responsibility Matrix (CRM), delineating assigned responsibilities for security, compliance and resilience controls between the Cloud Service Provider (CSP) and its customers.	5	
5.11	Cloud Computing	The use of cloud computing services must be risk-assessed. The risk profile of cloud computing must be assessed according to the type of cloud architecture, i.e. public cloud, private cloud, community cloud and hybrid cloud. A cloud risk assessment must include an analysis of security architecture and operations, as well as the following topics: As part of the cloud risk assessment, a review of roles and responsibilities must be completed to define which party is responsible for operating and monitoring each cyber risk control.	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
5.11-BP1	Governance and Enterprise Risk Management (ERM)	The ability of an organisation to govern and measure enterprise risk introduced by cloud computing, the ability to adequately assess the risk of a cloud provider, and the definition of roles and responsibilities	Functional	Subset Of	Risk Management Program	RSK-01	Mechanisms exist to facilitate the implementation of strategic, operational and tactical risk management controls that are aligned with: (1) The organization's Enterprise Risk Management (ERM); and (2) Industry-recognized cybersecurity risk management practices.	10	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.11-BP2	Legal issues	Potential legal issues include protection requirements for information and computer systems, security breach disclosure laws, regulatory requirements, privacy requirements and international laws or regulations	Functional	Subset Of	Third-Party Contract Requirements	TPM-05	Mechanisms exist to require contractual requirements for applicable security, compliance and resilience requirements with third-parties, reflecting the organization's needs to protect its Technology Assets, Applications, Services and/or Data (TAASD).	10	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.11-BP3	Compliance and audit	Maintaining and proving compliance when using cloud computing; evaluating how cloud computing affects compliance with internal security policies, as well as compliance requirements (regulatory, legislative and other)	Functional	Intersects With	Compliance Scope	CPL-01.2	Mechanisms exist to document and validate the scope of security, compliance and resilience controls that are determined to meet statutory, regulatory and/or contractual compliance obligations.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.11-BP3	Compliance and audit	Maintaining and proving compliance when using cloud computing; evaluating how cloud computing affects compliance with internal security policies, as well as compliance requirements (regulatory, legislative and other)	Functional	Intersects With	Conformity Assessment	CPL-01.4	Mechanisms exist to conduct assessments to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.11-BP4	Information governance	Governing data that is placed in the cloud, i.e. the identification and control of data in the cloud, compensating controls that can be used to deal with the loss of physical control when moving data to the cloud	Functional	Intersects With	Operationalizing Security, Compliance & Resilience Capabilities	GOV-15	Mechanisms exist to compel data and/or process owners to operationalize security, compliance and resilience practices for Technology Assets, Applications, Services and/or Data (TAASD) under their control.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.11-BP4	Information governance	Governing data that is placed in the cloud, i.e. the identification and control of data in the cloud, compensating controls that can be used to deal with the loss of physical control when moving data to the cloud	Functional	Intersects With	Compensating Countermeasures	RSK-06.2	Mechanisms exist to identify and implement compensating countermeasures to reduce risk and exposure to threats.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
5.12	End User Developed Systems (End User Computing)	The risk from any end user-developed systems should be assessed given that end users may develop systems that do not follow formal IT standards. This may increase the risk of security incidents relating to data security or availability outages.	Functional	Intersects With	Product Testing & Reviews	TDA-02.10	Mechanisms exist to regularly review Technology Assets, Applications and/or Services (TAAS) for an appropriate level of security and resiliency based on applicable risks and threats.	5	
5.13	Staff Vetting Process	The screening of staff is an important control used to minimise personnel risks. Registrants must implement a staff vetting process.	Functional	Intersects With	Personnel Screening	HRS-04	Mechanisms exist to manage personnel security risk by screening individuals prior to authorizing access.	8	
5.14	The Security Review of New Projects and IT Systems	New projects that involve data or systems classified as critical, must be subject to a technology risk assessment to identify and respond to any potential new risks introduced. Minor changes should be security reviewed as part of the standard change process.	Functional	Intersects With	Security, Compliance & Resilience in Project Management	PRM-04	Mechanisms exist to assess security, compliance and resilience controls as part of Technology Assets, Applications and/or Services (TAAS) project development to determine whether controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting requirements.	5	
5.14	The Security Review of New Projects and IT Systems	New projects that involve data or systems classified as critical, must be subject to a technology risk assessment to identify and respond to any potential new risks introduced. Minor changes should be security reviewed as part of the standard change process.	Functional	Intersects With	Security, Compliance & Resilience Requirements Definition	PRM-05	Mechanisms exist to proactively govern Technology Assets, Applications and/or Services (TAAS) by: (1) Defining technical security, compliance and resilience requirements; and	5	
5.14	The Security Review of New Projects and IT Systems	New projects that involve data or systems classified as critical, must be subject to a technology risk assessment to identify and respond to any potential new risks introduced. Minor changes should be security reviewed as part of the standard change process.	Functional	Intersects With	Business Impact Analysis (BIA)	RSK-08	Mechanisms exist to conduct a Business Impact Analysis (BIA) to identify and assess security, compliance and resilience risks.	5	
6	SECTION II – DETECT AND PROTECT CONTROLS	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
6.1	IT Service Management	IT service management processes should be in place to assist in the management of stable and secure IT systems, services and operations and should include:	Functional	Subset Of	Security, Compliance & Resilience Program (SCRPI)	GOV-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience governance controls.	10	
6.1-BP1	IT Service Management	Configuration management	Functional	Subset Of	Configuration Management Program	CFG-01	Mechanisms exist to facilitate the implementation of configuration management controls.	10	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.1-BP2	IT Service Management	Change management	Functional	Subset Of	Change Management Program	CHG-01	Mechanisms exist to facilitate the implementation of a change management program.	10	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.1-BP3	IT Service Management	Software release management	Functional	Subset Of	Technology Development & Acquisition	TDA-01	Mechanisms exist to facilitate the implementation of tailored development and acquisition strategies, contract tools and procurement methods to meet unique business needs.	10	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.1-BP4	IT Service Management	Incident and problem management	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.1-BP5	IT Service Management	Performance and capacity management	Functional	Subset Of	Capacity & Performance Management	CAP-01	Mechanisms exist to facilitate the implementation of capacity management controls to ensure optimal system performance to meet expected and anticipated future capacity requirements.	10	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.2	Threat Intelligence and Vulnerability Alerting	Registrants should consider using threat intelligence and vulnerability alerting service to provide information about new cyber threats and vulnerabilities. This information can then be used to assist with threat response protective measures.	Functional	Intersects With	Threat Intelligence Feeds	THR-03	Mechanisms exist to maintain situational awareness of vulnerabilities and evolving threats by leveraging the knowledge of attacker tactics, techniques and procedures to facilitate the implementation of preventative and compensating controls.	5	
6.3	IT Incident Management	An IT incident occurs when there is an unexpected disruption to the standard delivery of IT services. An incident management process must be in place with the objective of restoring normal IT service following the incident and with minimal impact to business operations.	Functional	Intersects With	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BCDR) playbooks).	5	
6.3	IT Incident Management	An IT incident occurs when there is an unexpected disruption to the standard delivery of IT services. An incident management process must be in place with the objective of restoring normal IT service following the incident and with minimal impact to business operations.	Functional	Intersects With	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
6.4	IT Security Incident Management	A formal IT security incident response process must be established. Consideration should be given to creating a Computer Security Incident Response Team (CSIRT). All employees, contractors and third-party users must be made aware of the procedure for reporting incidents. A post-incident review should take place, this review should establish the root cause of the incident and conclude any remedial action required. The IT incident management procedure should also define when a major incident becomes a crisis. Roles and responsibilities should be defined. Management of communications to internal and external stakeholders should also be clearly defined. Scenario-based or "tabletop" response exercises should be held to prepare for any real incidents that may occur and test the processes in place. Registrants should consider contracting with an external organisation who specialise in security incident investigation and response so that their services are available in the event of a major security incident.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	
6.4	IT Security Incident Management	A formal IT security incident response process must be established. Consideration should be given to creating a Computer Security Incident Response Team (CSIRT). All employees, contractors and third-party users must be made aware of the procedure for reporting incidents. A post-incident review should take place, this review should establish the root cause of the incident and conclude any remedial action required. The IT incident management procedure should also define when a major incident becomes a crisis. Roles and responsibilities should be defined. Management of communications to internal and external stakeholders should also be clearly defined. Scenario-based or "tabletop" response exercises should be held to prepare for any real incidents that may occur and test the processes in place. Registrants should consider contracting with an external organisation who specialise in security incident investigation and response so that their services are available in the event of a major security incident.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	5	
6.4	IT Security Incident Management	A formal IT security incident response process must be established. Consideration should be given to creating a Computer Security Incident Response Team (CSIRT). All employees, contractors and third-party users must be made aware of the procedure for reporting incidents. A post-incident review should take place, this review should establish the root cause of the incident and conclude any remedial action required. The IT incident management procedure should also define when a major incident becomes a crisis. Roles and responsibilities should be defined. Management of communications to internal and external stakeholders should also be clearly defined. Scenario-based or "tabletop" response exercises should be held to prepare for any real incidents that may occur and test the processes in place. Registrants should consider contracting with an external organisation who specialise in security incident investigation and response so that their services are available in the event of a major security incident.	Functional	Intersects With	Incident Classification & Prioritization	IRO-02.4	Mechanisms exist to identify classes of incidents and actions to take to ensure the continuation of organizational missions and business functions.	5	
6.4	IT Security Incident Management	A formal IT security incident response process must be established. Consideration should be given to creating a Computer Security Incident Response Team (CSIRT). All employees, contractors and third-party users must be made aware of the procedure for reporting incidents. A post-incident review should take place, this review should establish the root cause of the incident and conclude any remedial action required. The IT incident management procedure should also define when a major incident becomes a crisis. Roles and responsibilities should be defined. Management of communications to internal and external stakeholders should also be clearly defined. Scenario-based or "tabletop" response exercises should be held to prepare for any real incidents that may occur and test the processes in place. Registrants should consider contracting with an external organisation who specialise in security incident investigation and response so that their services are available in the event of a major security incident.	Functional	Intersects With	Incident Response Plan (IRP)	IRO-04	Mechanisms exist to maintain and make available a current and viable Incident Response Plan (IRP) to all stakeholders.	5	
6.4	IT Security Incident Management	A formal IT security incident response process must be established. Consideration should be given to creating a Computer Security Incident Response Team (CSIRT). All employees, contractors and third-party users must be made aware of the procedure for reporting incidents. A post-incident review should take place, this review should establish the root cause of the incident and conclude any remedial action required. The IT incident management procedure should also define when a major incident becomes a crisis. Roles and responsibilities should be defined. Management of communications to internal and external stakeholders should also be clearly defined. Scenario-based or "tabletop" response exercises should be held to prepare for any real incidents that may occur and test the processes in place. Registrants should consider contracting with an external organisation who specialise in security incident investigation and response so that their services are available in the event of a major security incident.	Functional	Intersects With	Incident Response Testing	IRO-06	Mechanisms exist to formally test incident response capabilities through realistic exercises to determine the operational effectiveness of those capabilities.	5	
6.4	IT Security Incident Management	A formal IT security incident response process must be established. Consideration should be given to creating a Computer Security Incident Response Team (CSIRT). All employees, contractors and third-party users must be made aware of the procedure for reporting incidents. A post-incident review should take place, this review should establish the root cause of the incident and conclude any remedial action required. The IT incident management procedure should also define when a major incident becomes a crisis. Roles and responsibilities should be defined. Management of communications to internal and external stakeholders should also be clearly defined. Scenario-based or "tabletop" response exercises should be held to prepare for any real incidents that may occur and test the processes in place. Registrants should consider contracting with an external organisation who specialise in security incident investigation and response so that their services are available in the event of a major security incident.	Functional	Intersects With	Integrated Security Incident Response Team (ISIRT)	IRO-07	Mechanisms exist to establish an integrated team of cybersecurity, IT and business function representatives that are capable of addressing cybersecurity and data protection incident response operations.	5	
6.4	IT Security Incident Management	A formal IT security incident response process must be established. Consideration should be given to creating a Computer Security Incident Response Team (CSIRT). All employees, contractors and third-party users must be made aware of the procedure for reporting incidents. A post-incident review should take place, this review should establish the root cause of the incident and conclude any remedial action required. The IT incident management procedure should also define when a major incident becomes a crisis. Roles and responsibilities should be defined. Management of communications to internal and external stakeholders should also be clearly defined. Scenario-based or "tabletop" response exercises should be held to prepare for any real incidents that may occur and test the processes in place. Registrants should consider contracting with an external organisation who specialise in security incident investigation and response so that their services are available in the event of a major security incident.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
6.4	IT Security Incident Management	A formal IT security incident response process must be established. Consideration should be given to creating a Computer Security Incident Response Team (CSIRT). All employees, contractors and third-party users must be made aware of the procedure for reporting incidents. A post-incident review should take place, this review should establish the root cause of the incident and conclude any remedial action required. The IT incident management procedure should also define when a major incident becomes a crisis. Roles and responsibilities should be defined. Management of communications to internal and external stakeholders should also be clearly defined. Scenario-based or "tabletop" response exercises should be held to prepare for any real incidents that may occur and test the processes in place. Registrants should consider contracting with an external organisation who specialise in security incident investigation and response so that their services are available in the event of a major security incident.	Functional	Intersects With	Root Cause Analysis (RCA) & Lessons Learned	IRO-13	Mechanisms exist to incorporate lessons learned from analyzing and resolving cybersecurity and data protection incidents to reduce the likelihood or impact of future incidents.	5	
6.5	Notification of Cyber Reporting Events to the Authority	A cyber reporting event is defined as: "Any act that results in unauthorised access to, disruption or misuse of the electronic systems or information stored on such systems of a licensed undertaking, including any breach of security leading to the loss or unlawful destruction or unauthorised disclosure of or access to such systems or information", where - Only cyber reporting events resulting in significant adverse impact to the regulated entity's operations, their policyholders or clients, must be reported to the Authority. When in doubt about whether an event is reportable, registrants should consult with the Authority for guidance. A Principal Representative (for insurers) and appropriate officer (for insurance managers and intermediaries) must notify the Authority within 72 hours from the time that there is either a determination or a confirmation of an event (whichever is sooner). Following the initial notification, registrants are expected to keep the Authority regularly updated on progress throughout the remediation of the incident. An incident report containing details of the incident, the root-cause, actions taken to minimise impact and any actual adverse impact to the organisation must be prepared. This must be submitted within 14 days of the initial incident notification date. If root cause has not been confirmed then the report must still be submitted detailing information known to date. The Authority may then request further updates but this will be determined on a case by case basis. Registrants are expected to maintain logs of all cybersecurity incidents together with details of actions taken to resolve them. Incident investigation and response logs (note this does not include actual system event logs) must be available for inspection upon the Authority's request at any time and kept for a minimum of five years.	Functional	Intersects With	Serious Incident Reporting	IRO-10.5	Mechanisms exist to report any serious incident involving the organization's Technology Assets, Applications, Services and/or Data (TAASD) to relevant authorities in the locality where the incident occurred, in accordance with mandatory reporting: (1) Requirements; and (2) Timelines.	5	
6.5(a)	Notification of Cyber Reporting Events to the Authority	a cyber reporting event has the likelihood of adversely impacting policyholders or clients;	Functional	Intersects With	Serious Incident Reporting	IRO-10.5	Mechanisms exist to report any serious incident involving the organization's Technology Assets, Applications, Services and/or Data (TAASD) to relevant authorities in the locality where the incident occurred, in accordance with mandatory reporting: (1) Requirements; and (2) Timelines.	5	
6.5(b)	Notification of Cyber Reporting Events to the Authority	an insurer has reached a view that there is a likelihood that loss of its system availability will have an adverse impact on its insurance business;	Functional	Intersects With	Serious Incident Reporting	IRO-10.5	Mechanisms exist to report any serious incident involving the organization's Technology Assets, Applications, Services and/or Data (TAASD) to relevant authorities in the locality where the incident occurred, in accordance with mandatory reporting: (1) Requirements; and (2) Timelines.	5	
6.5(c)	Notification of Cyber Reporting Events to the Authority	an insurer has reached a view that there is a likelihood that the integrity of its information or data has been compromised and may have an adverse impact on its insurance business;	Functional	Intersects With	Serious Incident Reporting	IRO-10.5	Mechanisms exist to report any serious incident involving the organization's Technology Assets, Applications, Services and/or Data (TAASD) to relevant authorities in the locality where the incident occurred, in accordance with mandatory reporting: (1) Requirements; and (2) Timelines.	5	
6.5(d)	Notification of Cyber Reporting Events to the Authority	an insurer has become aware that there is a likelihood that there has been unauthorised access to its information systems whereby such would have an adverse impact on its insurance business; or	Functional	Intersects With	Serious Incident Reporting	IRO-10.5	Mechanisms exist to report any serious incident involving the organization's Technology Assets, Applications, Services and/or Data (TAASD) to relevant authorities in the locality where the incident occurred, in accordance with mandatory reporting: (1) Requirements; and (2) Timelines.	5	
6.5(e)	Notification of Cyber Reporting Events to the Authority	an event has occurred for which a notice is required to be provided to a regulatory body or government agency.	Functional	Intersects With	Serious Incident Reporting	IRO-10.5	Mechanisms exist to report any serious incident involving the organization's Technology Assets, Applications, Services and/or Data (TAASD) to relevant authorities in the locality where the incident occurred, in accordance with mandatory reporting: (1) Requirements; and (2) Timelines.	5	
6.6	Logical Access Management	Procedures must be in place to manage the allocation of access rights to information systems and services. Employees, third parties and customers using IT systems must be authorised to do so through an approved process to ensure the access and level of privilege is appropriate to their role. Roles and areas of responsibility should be segregated as much as possible to minimise opportunities for misuse, abuse of privileges and unauthorised or unintentional modification. Access to systems and data should only be granted to individuals confirmed as having a requirement. An audit log of all logical access changes should be maintained.	Functional	Intersects With	Separation of Duties (SoD)	HRS-11	Mechanisms exist to implement and maintain Separation of Duties (SoD) to prevent potential inappropriate activity without collusion.	3	
6.6	Logical Access Management	Procedures must be in place to manage the allocation of access rights to information systems and services. Employees, third parties and customers using IT systems must be authorised to do so through an approved process to ensure the access and level of privilege is appropriate to their role. Roles and areas of responsibility should be segregated as much as possible to minimise opportunities for misuse, abuse of privileges and unauthorised or unintentional modification. Access to systems and data should only be granted to individuals confirmed as having a requirement. An audit log of all logical access changes should be maintained.	Functional	Intersects With	Identity & Access Management (IAM)	IAC-01	Mechanisms exist to facilitate the implementation of identification and access management controls.	5	
6.6	Logical Access Management	Procedures must be in place to manage the allocation of access rights to information systems and services. Employees, third parties and customers using IT systems must be authorised to do so through an approved process to ensure the access and level of privilege is appropriate to their role. Roles and areas of responsibility should be segregated as much as possible to minimise opportunities for misuse, abuse of privileges and unauthorised or unintentional modification. Access to systems and data should only be granted to individuals confirmed as having a requirement. An audit log of all logical access changes should be maintained.	Functional	Intersects With	Role-Based Access Control (RBAC)	IAC-08	Mechanisms exist to enforce Role-Based Access Control (RBAC) for Technology Assets, Applications, Services and/or Data (TAASD) to restrict access to individuals assigned specific roles with legitimate business needs.	5	
6.6	Logical Access Management	Procedures must be in place to manage the allocation of access rights to information systems and services. Employees, third parties and customers using IT systems must be authorised to do so through an approved process to ensure the access and level of privilege is appropriate to their role. Roles and areas of responsibility should be segregated as much as possible to minimise opportunities for misuse, abuse of privileges and unauthorised or unintentional modification. Access to systems and data should only be granted to individuals confirmed as having a requirement. An audit log of all logical access changes should be maintained.	Functional	Intersects With	Account Management	IAC-15	Mechanisms exist to: (1) Define authorized system account types; (2) Define prohibited system account types; and (3) Proactively govern individual, group, system, service, application, guest and temporary accounts.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
6.6	Logical Access Management	Procedures must be in place to manage the allocation of access rights to information systems and services. Employees, third parties and customers using IT systems must be authorised to do so through an approved process to ensure the access and level of privilege is appropriate to their role. Roles and areas of responsibility should be segregated as much as possible to minimise opportunities for misuse, abuse of privileges and unauthorised or unintentional modification. Access to systems and data should only be granted to individuals confirmed as having a requirement. An audit log of all logical access changes should be maintained.	Functional	Intersects With	Management Approval For Privileged Accounts	IAC-21.3	Mechanisms exist to restrict the assignment of privileged accounts to management-approved personnel and/or roles.	5	
6.6	Logical Access Management	Procedures must be in place to manage the allocation of access rights to information systems and services. Employees, third parties and customers using IT systems must be authorised to do so through an approved process to ensure the access and level of privilege is appropriate to their role. Roles and areas of responsibility should be segregated as much as possible to minimise opportunities for misuse, abuse of privileges and unauthorised or unintentional modification. Access to systems and data should only be granted to individuals confirmed as having a requirement. An audit log of all logical access changes should be maintained.	Functional	Intersects With	Management Approval For New or Changed Accounts	IAC-28.1	Mechanisms exist to ensure management approvals are required for new accounts or changes in permissions to existing accounts.	5	
6.7	Awareness and Training	Staff cyber risk awareness training must be completed at least annually. Staff responsible for cyber risk and cybersecurity should also have the relevant skills and training to carry out their role.	Functional	Intersects With	Security, Compliance & Resilience Awareness Training	SAT-02	Mechanisms exist to provide all employees and contractors appropriate security, compliance and resilience awareness education and training that is relevant for their job function.	5	
6.8	Data Classification and Security	Information should be classified and protected in a manner commensurate with its sensitivity, value and criticality. If personal or otherwise sensitive information is used for testing purposes, all sensitive details and content should be removed or anonymised.	Functional	Intersects With	Data & Asset Classification	DCH-02	Mechanisms exist to ensure data and assets are categorized in accordance with applicable statutory, regulatory and contractual requirements.	5	
6.9	Data Loss Prevention (DLP)	Registrants must perform an assessment of their Data Loss Prevention (DLP) control requirements. Typically, this assessment would reference the level of data classification, potential unauthorised data egress points and appropriate mitigating controls.	Functional	Intersects With	Data Loss Prevention (DLP)	NET-17	Automated mechanisms exist to implement Data Loss Prevention (DLP) to protect sensitive information as it is stored, transmitted and processed.	5	
6.9	Data Loss Prevention (DLP)	Registrants must perform an assessment of their Data Loss Prevention (DLP) control requirements. Typically, this assessment would reference the level of data classification, potential unauthorised data egress points and appropriate mitigating controls.	Functional	Intersects With	Business Process Definition	PRM-06	Mechanisms exist to define business processes with consideration for security, compliance and resilience that determines: (1) The resulting risk to organizational operations, assets, individuals and other organizations; and (2) Information protection needs arising from the defined business processes and revises the processes as necessary, until an achievable set of protection needs is obtained.	5	
6.10	Data Protection and Governance	Registrants must perform an assessment of their compliance against applicable data protection requirements. Where Personally Identifiable Information (PII) is processed, this must be in accordance with data protection/privacy laws relevant to each jurisdiction of operation. Data governance controls should be documented to define how data assets are formally managed throughout the enterprise. These should include: data quality, handling, security and retention. Storage limitation should also be defined, along with setting limits as to how long data is to be stored i.e. to prevent unnecessary storage.	Functional	Subset Of	Conformity Assessment	CPL-01.4	Mechanisms exist to conduct assessments to demonstrate security, compliance and/or resilience capability conformity with applicable cybersecurity and data protection laws, regulations and/or contractual obligations.	10	
6.11	Mobile Computing	Mobile computing services to include Bring Your Own Device (BYOD) services, must be subject to a risk assessment and then secured with appropriate controls.	Functional	Subset Of	Centralized Management Of Mobile Devices	MDM-01	Mechanisms exist to implement and govern Mobile Device Management (MDM) controls.	10	
6.12	Protection against Malicious Code	Controls to detect and block malicious code (or suitable mitigating controls) must be deployed at both the endpoint (i.e. desktop and mobile devices), as well as the network level. Malicious code includes computer viruses, ransomware, spyware, network worms, Trojan horses and backdoors.	Functional	Subset Of	Malicious Code Protection (Anti-Malware)	END-04	Mechanisms exist to utilize anti-malware technologies to detect and eradicate malicious code.	10	
6.13	Securing Nonpublic Data	Data classified as nonpublic must be protected by an appropriate level of security. The Authority requires that nonpublic data (including Personally Identifiable Information - PII), is protected by encryption at rest and when transmitted over public networks. Where encryption is not feasible, mitigating controls may be used, by exception.	Functional	Subset Of	Sensitive / Regulated Data Protection	DCH-01.2	Mechanisms exist to protect sensitive and/or regulated data wherever it is processed and/or stored.	10	
6.14	Data Backup Management	Registrants should define a data backup strategy which references the classification level of data. Registrants should carry out periodic testing to ensure that backups can be restored	Functional	Intersects With	Data Backups	BCD-11	Mechanisms exist to create recurring backups of data, software and/or system images, as well as verify the integrity of these backups, to ensure the availability of the data to satisfy Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs).	5	
6.14	Data Backup Management	Registrants should define a data backup strategy which references the classification level of data. Registrants should carry out periodic testing to ensure that backups can be restored	Functional	Intersects With	Test Restoration Using Sampling	BCD-11.5	Mechanisms exist to utilize sampling of available backups to test recovery capabilities as part of business continuity plan testing.	5	
6.15	Penetration Testing and Vulnerability Assessments	Registrants must assess their risk and determine a suitable security testing programme. The following should be considered as a minimum baseline:	Functional	Subset Of	Information Assurance (IA) Operations	IAO-01	Mechanisms exist to facilitate the implementation of security, compliance and resilience assessment and authorization controls.	10	
6.15-BP1	Penetration Testing and Vulnerability Assessments	Regular penetration testing of internet-facing services by an independent and qualified testing company	Functional	Intersects With	Penetration Testing	VPM-07	Mechanisms exist to conduct penetration testing on Technology Assets, Applications and/or Services (TAAS).	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.15-BP2	Penetration Testing and Vulnerability Assessments	A security assessment for any new internet-facing services, or changes to existing services to determine if they need to be penetration tested before they go live	Functional	Intersects With	Assessments	IAO-02	Mechanisms exist to formally assess the security, compliance and resilience controls in Technology Assets, Applications and/or Services (TAAS) through Information Assurance Program (IAP) activities to determine the extent to which the controls are implemented correctly, operating as intended and producing the desired outcome with respect to meeting expected requirements.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.15-BP3	Penetration Testing and Vulnerability Assessments	Internal vulnerability scanning	Functional	Intersects With	Internal Vulnerability Assessment Scans	VPM-06.7	Mechanisms exist to perform quarterly internal vulnerability scans, which includes all segments of the organization's internal network, as well as rescans until passing results are obtained or all "high" vulnerabilities are resolved, as defined by the Common Vulnerability Scoring System (CVSS).	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.15-BP4	Penetration Testing and Vulnerability Assessments	External vulnerability scanning	Functional	Intersects With	Acceptable Discoverable Information	VPM-06.8	Mechanisms exist to define what information is allowed to be discoverable by adversaries and take corrective actions to remediate non-compliant Technology Assets, Applications and/or Services (TAAS).	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.15-BP5	Penetration Testing and Vulnerability Assessments	Baseline standards to document secure configuration baselines of all network devices	Functional	Subset Of	Secure Baseline Configurations	CFG-02	Mechanisms exist to develop, document and maintain secure baseline configurations for Technology Assets, Applications and/or Services (TAAS) that are consistent with industry-accepted system hardening standards.	10	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.16	Patch Management	Registrants must have patch management procedures that define the identification, categorisation and prioritisation of security patches. Registrants must pay close attention to a vendor's end of support date as patches may no longer be available after this date.	Functional	Intersects With	Unsupported Technology Assets, Applications and/or Services (TAAS)	TDA-17	Mechanisms exist to prevent unsupported Technology Assets, Applications and/or Services (TAAS) by: (1) Removing and/or replacing TAAS when support for the components is no longer available from the developer, vendor or manufacturer; and (2) Requiring justification and documented approval for the continued use of unsupported TAAS required to satisfy mission/business needs.	5	
6.16	Patch Management	Registrants must have patch management procedures that define the identification, categorisation and prioritisation of security patches. Registrants must pay close attention to a vendor's end of support date as patches may no longer be available after this date.	Functional	Intersects With	Software & Firmware Patching	VPM-05	Mechanisms exist to conduct software patching for all deployed Technology Assets, Applications and/or Services (TAAS), including firmware.	8	
6.17	Data Deletion/Sanitisation Policy	Data deletion and sanitisation of all media types that are used by the business should be documented and communicated to the appropriate staff	Functional	Intersects With	System Media Sanitization	DCH-09	Mechanisms exist to sanitize system media with the strength and integrity commensurate with the classification or sensitivity of the information prior to disposal, release out of organizational control or release for reuse.	5	
6.17	Data Deletion/Sanitisation Policy	Data deletion and sanitisation of all media types that are used by the business should be documented and communicated to the appropriate staff	Functional	Intersects With	System Media Sanitization Documentation	DCH-09.1	Mechanisms exist to supervise, track, document and verify system media sanitization and disposal actions.	5	

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
6.18	Network Security Management	Network segregation must be used effectively to create zones of enhanced security within a network. Any service accessing the internet must first be routed through a Demilitarised Zone (DMZ). This is a physical or logical subnetwork that separates an organisation's external-facing services to an untrusted network. Network security tools should be used to detect network intrusions and to provide alerts when an intrusion occurs. Examples of a network intrusion detection tool include a network Intrusion Detection System/Intrusion Protection System (IDS/IPS).	Functional	Intersects With	Layered Network Defenses	NET-02	Mechanisms exist to implement security functions as a layered structure that minimizes interactions between layers of the design and avoids any dependence by lower layers on the functionality or correctness of higher layers.	5	
6.18	Network Security Management	Network segregation must be used effectively to create zones of enhanced security within a network. Any service accessing the internet must first be routed through a Demilitarised Zone (DMZ). This is a physical or logical subnetwork that separates an organisation's external-facing services to an untrusted network. Network security tools should be used to detect network intrusions and to provide alerts when an intrusion occurs. Examples of a network intrusion detection tool include a network Intrusion Detection System/Intrusion Protection System (IDS/IPS).	Functional	Intersects With	Network Segmentation (macrosegmentation)	NET-06	Mechanisms exist to implement network segmentation within network architectures to isolate Technology Assets, Applications and/or Services (TAAS) from other network resources.	5	
6.18	Network Security Management	Network segregation must be used effectively to create zones of enhanced security within a network. Any service accessing the internet must first be routed through a Demilitarised Zone (DMZ). This is a physical or logical subnetwork that separates an organisation's external-facing services to an untrusted network. Network security tools should be used to detect network intrusions and to provide alerts when an intrusion occurs. Examples of a network intrusion detection tool include a network Intrusion Detection System/Intrusion Protection System (IDS/IPS).	Functional	Intersects With	Network Intrusion Detection / Prevention Systems (NIDS / NIPS)	NET-08	Mechanisms exist to employ Network Intrusion Detection / Prevention Systems (NIDS/NIPS) to detect and/or prevent intrusions into the network.	5	
6.18	Network Security Management	Network segregation must be used effectively to create zones of enhanced security within a network. Any service accessing the internet must first be routed through a Demilitarised Zone (DMZ). This is a physical or logical subnetwork that separates an organisation's external-facing services to an untrusted network. Network security tools should be used to detect network intrusions and to provide alerts when an intrusion occurs. Examples of a network intrusion detection tool include a network Intrusion Detection System/Intrusion Protection System (IDS/IPS).	Functional	Intersects With	Use of Demilitarized Zones (DMZ)	WEB-02	Mechanisms exist to utilize a Demilitarized Zone (DMZ) to restrict inbound traffic to authorized Technology Assets, Applications and/or Services (TAAS) on certain services, protocols and ports.	5	
6.19	Distributed Denial of Service Defense (DDOS Defense)	Registrants should ensure they have conducted a risk assessment of DDOS attacks and then deploy the appropriate defences. The review should assess the following:	Functional	Intersects With	Denial of Service (DoS) Protection	NET-02.1	Automated mechanisms exist to protect against or limit the effects of denial of service attacks.	5	
6.19	Distributed Denial of Service Defense (DDOS Defense)	Registrants should ensure they have conducted a risk assessment of DDOS attacks and then deploy the appropriate defences. The review should assess the following:	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	
6.19-BP1	Distributed Denial of Service Defense (DDOS Defense)	Inherent risk from a DDOS attack to business services	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.19-BP2	Distributed Denial of Service Defense (DDOS Defense)	Detection controls: how quickly an attack could be detected	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.19-BP3	Distributed Denial of Service Defense (DDOS Defense)	Mitigation controls: how effectively traffic can be dropped/cleaned	Functional	Intersects With	Risk Assessment	RSK-04	Mechanisms exist to conduct recurring assessments of risk that includes the likelihood and magnitude of harm, from unauthorized access, use, disclosure, disruption, modification or destruction of the organization's Technology Assets, Applications, Services and/or Data (TAASD).	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.20	Secure Application Development	Where application development takes place, a Secure Development Lifecycle (SDLC) should document secure development practices, examples include:	Functional	Intersects With	Secure Development Life Cycle (SDLC) Management	PRM-07	Mechanisms exist to ensure changes to Technology Assets, Applications and/or Services (TAAS) within the Secure Development Life Cycle (SDLC) are controlled through formal change control procedures.	5	
6.20	Secure Application Development	Where application development takes place, a Secure Development Lifecycle (SDLC) should document secure development practices, examples include:	Functional	Intersects With	Secure Software Development Practices (SSDP)	TDA-06	Mechanisms exist to develop applications based on Secure Software Development Practices (SSDP).	5	
6.20-BP1	Secure Application Development	The testing of application modules using source code review, exception testing and compliance review to identify insecure coding practices and system vulnerabilities	Functional	Intersects With	Security, Compliance & Resilience Testing Throughout Development	TDA-09	Mechanisms exist to require system developers/integrators consult with security, compliance and/or resilience personnel to: (1) Create and implement a Security Testing and Evaluation (ST&E) plan, or similar capability; (2) implement a verifiable flaw remediation process to correct weaknesses and deficiencies identified during the control testing and evaluation process; and (3) Document the results.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.20-BP2	Secure Application Development	The use of separate environments for unit, integration and user acceptance testing	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.20-BP3	Secure Application Development	The separation of development and testing environments from the production environment	Functional	Intersects With	Separation of Development, Testing and Operational Environments	TDA-08	Mechanisms exist to manage separate development, testing and operational environments to reduce the risks of unauthorized access or changes to the operational environment and to ensure no impact to production Technology Assets, Applications and/or Services (TAAS).	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.21	Logging and Monitoring	Registrants must complete an assessment of their logging and monitoring requirements. The following controls should be considered as part of this review:	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	
6.21	Logging and Monitoring	Registrants must complete an assessment of their logging and monitoring requirements. The following controls should be considered as part of this review:	Functional	Intersects With	Continuous Monitoring	MON-01	Mechanisms exist to facilitate the implementation of enterprise-wide monitoring controls.	5	
6.21-BP1	Logging and Monitoring	System event logs must be retained and stored in accordance with business and regulatory requirements, taking into account system criticality	Functional	Intersects With	Event Log Retention	MON-10	Mechanisms exist to retain event logs for a time period consistent with records retention requirements to provide support for after-the-fact investigations of security incidents and to meet statutory, regulatory and contractual retention requirements.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.21-BP2	Logging and Monitoring	Where logs contain personal data, they must be treated in accordance with the relevant privacy law requirements	Functional	Intersects With	Sensitive Event Log Information	MON-03.1	Mechanisms exist to protect sensitive and/or regulated data contained in log files.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.21-BP2	Logging and Monitoring	Where logs contain personal data, they must be treated in accordance with the relevant privacy law requirements	Functional	Intersects With	Cryptographic Protection of Event Log Information	MON-08.3	Cryptographic mechanisms exist to protect the integrity of event logs and audit tools.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.21-BP3	Logging and Monitoring	All security logs must be protected from unauthorised access, disclosure, modification or destruction	Functional	Intersects With	Protection of Event Logs	MON-08	Mechanisms exist to protect event logs and audit tools from unauthorized access, modification and deletion.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.21-BP4	Logging and Monitoring	Anomalous activity must be detected and investigated in order to understand the potential risk to the network	Functional	Intersects With	Anomalous Behavior	MON-16	Mechanisms exist to utilize User & Entity Behavior Analytics (UEBA) and/or User Activity Monitoring (UAM) solutions to detect and respond to anomalous behavior that could indicate account compromise or other malicious activities.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.21-BP5	Logging and Monitoring	Security events must be monitored to facilitate the prompt detection of malicious activity	Functional	Intersects With	Security Event Monitoring	MON-01.8	Mechanisms exist to review event logs on an ongoing basis and escalate incidents in accordance with established timelines and procedures.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
6.21-BP6	Logging and Monitoring	Data that allows for the complete and accurate reconstruction of all financial transactions and accounting must be maintained	Functional	Intersects With	System Generated Alerts	MON-01.4	Mechanisms exist to generate, monitor, correlate and respond to alerts from physical, cybersecurity, data protection and supply chain activities to achieve integrated situational awareness.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.21-BP6	Logging and Monitoring	Data that allows for the complete and accurate reconstruction of all financial transactions and accounting must be maintained	Functional	Intersects With	Content of Event Logs	MON-03	Mechanisms exist to configure Technology Assets, Applications and/or Services (TAAS) to produce event logs that contain sufficient information to, at a minimum: (1) Establish what type of event occurred; (2) When (date and time) the event occurred; (3) Where the event occurred; (4) The source of the event; (5) The outcome (success or failure) of the event; and (6) The identity of any user/subject associated with the event.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
6.22	Use of Cryptography	Registrants should evaluate cryptographic implementations, and ensure that only cryptographic modules based on authoritative standards, and reputable protocols are installed. The strength of cryptography depends not only on the algorithm and key size but also on implementation. Testing should be conducted before any cryptographic services go into production to identify any security issues.	Functional	Intersects With	Control Conformity Monitoring	CPL-03	Mechanisms exist to validate that Technology Assets, Applications, Services and/or Data (TAASD) conform to the organization's security, compliance and/or resilience policies, standards and other applicable requirements.	5	
6.22	Use of Cryptography	Registrants should evaluate cryptographic implementations, and ensure that only cryptographic modules based on authoritative standards, and reputable protocols are installed. The strength of cryptography depends not only on the algorithm and key size but also on implementation. Testing should be conducted before any cryptographic services go into production to identify any security issues.	Functional	Intersects With	Use of Cryptographic Controls	CRY-01	Mechanisms exist to facilitate the implementation of cryptographic protections controls using known public standards and trusted cryptographic technologies.	5	
7	SECTION III – RESPONSE AND RECOVERY CONTROLS	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
7.1	Business Continuity and Disaster Recovery Planning	Registrants must implement effective Business Continuity Planning (BCP) and Disaster Recovery (DR) policies and procedures to include:	Functional	Intersects With	Publishing Security, Compliance & Resilience Documentation	GOV-02	Mechanisms exist to establish, maintain and disseminate policies, standards and procedures necessary for secure, compliant and resilient capabilities.	5	
7.1	Business Continuity and Disaster Recovery Planning	Registrants must implement effective Business Continuity Planning (BCP) and Disaster Recovery (DR) policies and procedures to include:	Functional	Intersects With	Business Continuity Management System (BCMS)	BCD-01	Mechanisms exist to facilitate the implementation of contingency planning controls to help ensure resilient Technology Assets, Applications and/or Services (TAAS) (e.g., Continuity of Operations Plan (COOP) or Business Continuity & Disaster Recovery (BC/DR) playbooks).	5	
7.1	Business Continuity and Disaster Recovery Planning	Registrants must implement effective Business Continuity Planning (BCP) and Disaster Recovery (DR) policies and procedures to include:	Functional	Intersects With	Business Continuity & Disaster Recovery (BC/DR) Plans	BCD-01.7	Mechanisms exist for process owners to establish and maintain formal Business Continuity & Disaster Recovery (BC/DR) plans to ensure information is detailed enough, accurate and representative of current operations in order to sustain and/or restore operations under adverse conditions.	5	
7.1-BP1	Business Continuity and Disaster Recovery Planning	Regular documented business impact analysis exercises to determine the criticality of business process, recovery criticality and the likely impact resulting from different disaster scenarios	Functional	Intersects With	Business Impact Analysis (BIA)	RSK-08	Mechanisms exist to conduct a Business Impact Analysis (BIA) to identify and assess security, compliance and resilience risks.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
7.1-BP2	Business Continuity and Disaster Recovery Planning	BCP and DR plans must be tested at least annually. These tests must be documented and any issues identified and tracked for remediation	Functional	Intersects With	Contingency Plan Testing & Exercises	BCD-04	Mechanisms exist to conduct tests and/or exercises to evaluate the contingency plan's effectiveness and the organization's readiness to execute the plan.	5	Numbering was added to the control to improve mappability because the FD used standard bullet points without numbering.
8	Implementation	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
9	Definitions	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	